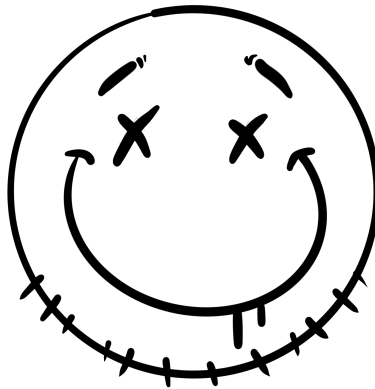




Lab 09: OS Hardening

Keith Schoen

CSEC3755-001

Dr. Daniel Pittman

8 April, 2026

Contents

1	Windows Hardening	1
1.1	Review User Accounts	1
1.2	Configure Password Policy	1
1.3	Configure Account Lockout Policy	2
1.4	Disable Unnecessary Services	3
2	Linux Hardening	4
2.1	Review User Accounts in /etc/passwd	4
2.2	Configure Password Policy via /etc/login.defs	5
2.3	Configure Account Lockout Policy via PAM	5
2.4	Review and Manage Services	6
2.5	SSH Hardening	7
3	CIS Benchmark Comparison	8
3.1	Linux CIS Benchmark Checks	8
3.2	Windows CIS Benchmark Checks	9
4	Security Policy Draft	10
5	Reflection Questions	10
5.1	Policy vs. Technical Controls	10
5.2	Defense in Depth	10

1 Windows Hardening

1.1 Review User Accounts

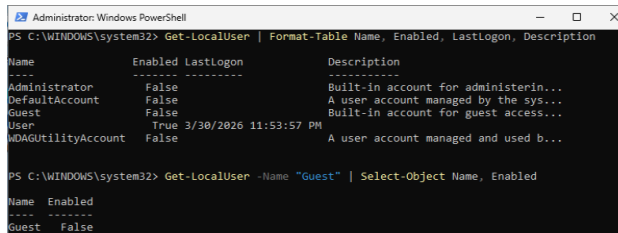


Figure 1: Screenshot showing all accounts and their enabled/disabled status.

From a hardening perspective, the guest account would count as an unnecessary access point. The guest account allows - although limited - access to a machine/network without any credentials eliminating the "hard part" for an attacker. This account is almost always unnecessary and should be disabled.

1.2 Configure Password Policy

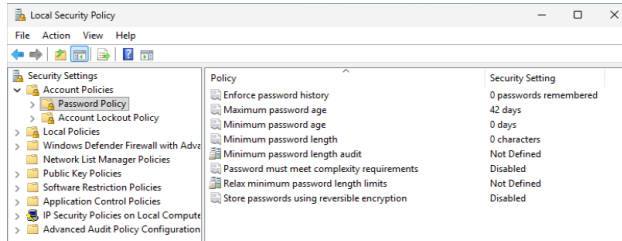


Figure 2: Screenshot showing default password policy

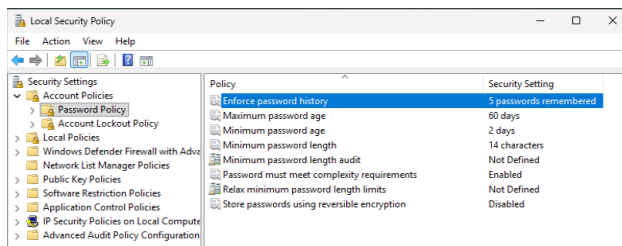


Figure 3: Screenshot showing updated password policy

People seem to hate coming up with and remembering passwords. Without having password minimums in place, everyone's password would be "user" and every machine and system

would be better off without password protection (at least people would be able to get on quicker!) To make sure that password protection is doing it's bare minimum, these simple policies must be put into place.

1.3 Configure Account Lockout Policy

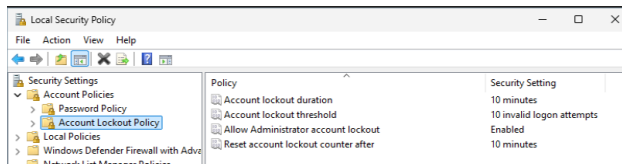


Figure 4: Screenshot showing default lockout policy

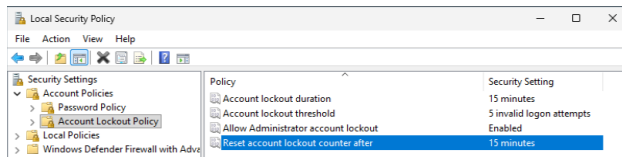


Figure 5: Screenshot showing updated lockout policy

It's not wise to give people too many tries or too much time with logging into an account. Adding just a little extra strictness to these policies makes it just that much more of a pain for even brute force tactics, hopefully making it not worth while.

[illegible]

```

Administrator: Windows PowerShell

PS C:\WINDOWS\system32> Get-Service -Name "RemoteRegistry", "Spooler", "SSDSPSRV", "XboxGip" -
ErrorAction SilentlyContinue | Format-Table DisplayName, Name, Status, StartType

DisplayName      Name              Status StartType
-----
Remote Registry  RemoteRegistry    Stopped Disabled
Print Spooler    Spooler           Running Automatic
SSDP Discovery   SSDSPSRV          Running Manual
Xbox Game Input  Protocol Driver   XboxGip          Stopped Manual

PS C:\WINDOWS\system32> Stop-Service -Name "Spooler" -Force -ErrorAction SilentlyContinue
PS C:\WINDOWS\system32> Set-Service -Name "Spooler" -StartupType Disabled
PS C:\WINDOWS\system32> Stop-Service -Name "SSDSPSRV" -Force -ErrorAction SilentlyContinue
PS C:\WINDOWS\system32> Set-Service -Name "SSDSPSRV" -StartupType Disabled
PS C:\WINDOWS\system32> Stop-Service -Name "XboxGip" -StartupType Disabled
PS C:\WINDOWS\system32> Get-Service -Name "RemoteRegistry", "Spooler", "SSDSPSRV", "XboxGip" -
ErrorAction SilentlyContinue | Format-Table DisplayName, Name, Status, StartType

DisplayName      Name              Status StartType
-----
Remote Registry  RemoteRegistry    Stopped Disabled
Print Spooler    Spooler           Stopped Disabled
SSDP Discovery   SSDSPSRV          Running Disabled
Xbox Game Input  Protocol Driver   XboxGip          Stopped Disabled

PS C:\WINDOWS\system32> Stop-Service -Name "SSDSPSRV" -Force -ErrorAction SilentlyContinue
PS C:\WINDOWS\system32> Set-Service -Name "RemoteRegistry", "Spooler", "SSDSPSRV", "XboxGip" -
ErrorAction SilentlyContinue | Format-Table DisplayName, Name, Status, StartType

DisplayName      Name              Status StartType
-----
Remote Registry  RemoteRegistry    Stopped Disabled
Print Spooler    Spooler           Stopped Disabled
SSDP Discovery   SSDSPSRV          Stopped Disabled
Xbox Game Input  Protocol Driver   XboxGip          Stopped Disabled

```

I focused on the the 4 services that were stated as unnecessary for the VM. After running a check, I disabled the 3 that were running/enabled and stopped/disabled them.

2 Linux Hardening

2.1 Review User Accounts in /etc/passwd

```
(kali@kali) ~
$ cat /etc/passwd
root:x:0:0:root:/root:/usr/bin/zsh
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mail List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
dhcpcd:x:100:65534:DHCP Client Daemon:/usr/lib/dhcpcd:/bin/false
systemd-timesync:x:991:991:systemd Time Synchronization:/:/usr/sbin/nologin
messagebus:x:990:990:System Message Bus:/nonexistent:/usr/sbin/nologin
tcpdump:x:101:102::/nonexistent:/usr/sbin/nologin
_rpc:x:102:65534::/run/rpcbind:/usr/sbin/nologin
sshd:x:989:65534:sshd user:/run/ssh:/usr/sbin/nologin
statd:x:103:65534::/var/lib/nfs:/usr/sbin/nologin
mysql:x:104:104:MariaDB Server:/nonexistent:/bin/false
tss:x:105:106:TPM software stack:/var/lib/tpm:/bin/false
stunnel4:x:988:988:stunnel service system account:/var/run/stunnel4:/usr/sbin/nologin
sshd:x:106:107::/nonexistent:/usr/sbin/nologin
redsocks:x:107:110::/var/run/redsocks:/usr/sbin/nologin
systemd-oom:x:987:987:systemd Userspace OOM Killer:/:/usr/sbin/nologin
gophish:x:108:112::/var/lib/gophish:/usr/sbin/nologin
iodine:x:109:65534::/run/iodine:/usr/sbin/nologin
miredo:x:110:65534::/var/run/miredo:/usr/sbin/nologin
Debian-snmp:x:111:113::/var/lib/snmp:/bin/false
redis:x:112:114::/var/lib/redis:/usr/sbin/nologin
postgres:x:113:115:PostgreSQL administrator:/var/lib/postgresql:/bin/bash
mosquitto:x:114:117::/var/lib/mosquitto:/usr/sbin/nologin
dnsmasq:x:999:65534:dnsmasq:/var/lib/misc:/usr/sbin/nologin
avahi:x:115:119:Avahi mDNS daemon:/run/avahi-daemon:/usr/sbin/nologin
inetsim:x:116:120::/var/lib/inetsim:/usr/sbin/nologin
_gvm:x:117:121::/var/lib/opensvas:/usr/sbin/nologin
usbmux:x:118:46:usbmux daemon:/var/lib/usbmux:/usr/sbin/nologin
cups-pk-helper:x:119:122:user for cups-pk-helper service:/nonexistent:/usr/sbin/nologin
pipewire:x:986:986:system user for pipewire:/nonexistent:/usr/sbin/nologin
fwupd-refresh:x:985:985:Firmware update daemon:/var/lib/fwupd:/usr/sbin/nologin
geoclue:x:120:124::/var/lib/geoclue:/usr/sbin/nologin
gnome-remote-desktop:x:984:984:GNOME Remote Desktop:/var/lib/gnome-remote-desktop:/usr/sbin/nologin
saned:x:121:125::/var/lib/saned:/usr/sbin/nologin
polkitd:x:983:983:User for polkitd:/:/usr/sbin/nologin
rtkit:x:122:126:RealtimeKit:/proc:/usr/sbin/nologin
colord:x:982:982:colord colour management daemon:/var/lib/colord:/usr/sbin/nologin
pcscd:x:981:981:PC/SC Smart Card Daemon:/:/usr/sbin/nologin
Debian-gdm:x:980:980:Gnome Display Manager:/var/lib/gdm3:/bin/false
kali:x:1000:1000:Kali User,,,:/home/kali:/usr/bin/zsh
```

Figures 10-11: Screenshots of all accounts

```
(kali@kali) ~
$ awk -F: '($3 == "0") {print}' /etc/passwd
root:x:0:0:root:/root:/usr/bin/zsh
```

Figure 12: Screenshot of accounts with UID 0

```
(kali@kali) ~
$ grep -v '/nologin|/false' /etc/passwd
root:x:0:0:root:/root:/usr/bin/zsh
sync:x:4:65534:sync:/bin:/bin/sync
postgres:x:113:115:PostgreSQL administrator:/var/lib/postgresql:/bin/bash
kali:x:1000:1000:Kali User,,,:/home/kali:/usr/bin/zsh
```

Figure 13: Screenshot of accounts that can log in

Besides the root user, there are a couple of additional accounts like kali and postgres. Based on passed labs, I think these both have something to do with the VM storage architecture.

2.2 Configure Password Policy via /etc/login.defs

```
(kali@kali)-[~]
$ grep -E "PASS_MAX_DAYS|PASS_MIN_DAYS|PASS_WARN_AGE|PASS_MIN_LEN" /etc/login.defs
# PASS_MAX_DAYS Maximum number of days a password may be used.
# PASS_MIN_DAYS Minimum number of days allowed between password changes.
# PASS_WARN_AGE Number of days warning given before a password expires.
PASS_MAX_DAYS 99999
PASS_MIN_DAYS 0
PASS_WARN_AGE 7
```

Figure 14: Screenshot of default password policies

```
# Password aging controls:
#
# PASS_MAX_DAYS Maximum number of days a password may be used.
# PASS_MIN_DAYS Minimum number of days allowed between password changes.
# PASS_WARN_AGE Number of days warning given before a password expires.
#
PASS_MAX_DAYS 90
PASS_MIN_DAYS 7
PASS_WARN_AGE 14
```

Figure 15: Screenshot of changes to password policy in /etc/login.defs

```
(kali@kali)-[~]
$ sudo chage -l kali
Last password change           : Jan 20, 2026
Password expires                : Apr 20, 2026
Password inactive               : never
Account expires                 : never
Minimum number of days between password change : 7
Maximum number of days between password change : 90
Number of days of warning before password expires : 14
```

Figure 16: Screenshot of changes to existing user kali's password policy

2.3 Configure Account Lockout Policy via PAM

```
(kali@kali)-[~]
$ cat /etc/pam.d/common-auth
#
# /etc/pam.d/common-auth - authentication settings common to all services
#
# This file is included from other service-specific PAM config files,
# and should contain a list of the authentication modules that define
# the central authentication scheme for use on the system
# (e.g., /etc/shadow, LDAP, Kerberos, etc.). The default is to use the
# traditional Unix authentication mechanisms.
#
# As of pam 1.0.1-6, this file is managed by pam-auth-update by default.
# To take advantage of this, it is recommended that you configure any
# local modules either before or after the default block, and use
# pam-auth-update to manage selection of other modules. See
# pam-auth-update(8) for details.
#
# here are the per-package modules (the "Primary" block)
auth [success=1 default=ignore] pam_unix.so nullok
# here's the fallback if no module succeeds
auth requisite pam_deny.so
# prime the stack with a positive return value if there isn't one already;
# this avoids us returning an error just because nothing sets a success code
# since the modules above will each just jump around
auth required pam_permit.so
# and here are more per-package modules (the "Additional" block)
# end of pam-auth-update config
```

Figure 17: Screenshot of current /etc/pam.d/common-auth file contents

```
# here are the per-package modules (the "Primary" block)
auth required pam_faillock.so preauth silent deny=5 unlock_time=900
auth [success=1 default=ignore] pam_unix.so nullok
auth [default=die] pam_faillock.so authfail deny=5 unlock_time=900
# here's the fallback if no module succeeds
```

Figure 18: Screenshot of two lines added to /etc/pam.d/common-auth file

```
# since the modules above will each just jump around
account required pam_permit.so
# and here are more per-package modules (the "Additional" block)
account required pam_faillock.so
# end of pam-auth-update config
```

Figure 19: Screenshot of line added to the end of `/etc/pam.d/common-account` file

```
(kali@kali)-[~]
$ faillock --user kali
kali:
when: Type Source Valid
2026-04-08 20:04:19 TTY /dev/pts/1 V
2026-04-08 20:04:32 TTY /dev/pts/1 V
2026-04-08 20:04:38 TTY /dev/pts/1 V
2026-04-08 20:04:45 TTY /dev/pts/1 V
2026-04-08 20:04:56 TTY /dev/pts/1 V
```

Figure 20: Screenshot of faillock test results.

Note about Section 2.3: I had to do this section of the lab three times as there was an reoccurring issue with the password policy. For some reason, I kept getting locked out of my account immediately after implementing the password policy. After several tries, I asked for help, spun to before the lockout policy was implemented and continued with the rest of the lab.

2.4 Review and Manage Services

```
(kali@kali)-[~]
$ sudo systemctl list-units --type=service --state=running
```

UNIT	LOAD	ACTIVE	SUB	DESCRIPTION
accounts-daemon.service	loaded	active	running	Accounts Service
colord.service	loaded	active	running	Manage, Install and Genes
containerd.service	loaded	active	running	containerd container run
cron.service	loaded	active	running	Regular background progr
dbus.service	loaded	active	running	D-Bus System Message Bus
docker.service	loaded	active	running	Docker Application Conta
fwupd.service	loaded	active	running	Firmware update daemon
gdm.service	loaded	active	running	GNOME Display Manager
ModemManager.service	loaded	active	running	Modem Manager
NetworkManager.service	loaded	active	running	Network Manager
pcscd.service	loaded	active	running	PC/SC Smart Card Daemon
polkit.service	loaded	active	running	Authorization Manager
power-profiles-daemon.service	loaded	active	running	Power Profiles daemon
rtkit-daemon.service	loaded	active	running	RealtimeKit Scheduling P
ssh.service	loaded	active	running	OpenBSD Secure Shell ser
systemd-journald.service	loaded	active	running	Journal Service
systemd-logind.service	loaded	active	running	User Login Management
systemd-oomd.service	loaded	active	running	Userspace Out-Of-Memory
systemd-udevd.service	loaded	active	running	Rule-based Manager for D
systemd-userdbd.service	loaded	active	running	User Database Manager
udisks2.service	loaded	active	running	Disk Manager
upower.service	loaded	active	running	Daemon for power managem
user@1000.service	loaded	active	running	User Manager for UID 1000
virtualbox-guest-utils.service	loaded	active	running	Virtualbox guest utils
wpa_supplicant.service	loaded	active	running	WPA supplicant

Legend: LOAD → Reflects whether the unit definition was properly loaded.
ACTIVE → The high-level unit activation state, i.e. generalization of

lines 1-29...skipping...

Figure 21: Screenshot of running services

```
(kali@kali)~$ sudo ss -tulpin
[sudo] password for kali:
Netid State Recv-Q Send-Q Local Address:Port Peer Address:Port
Process
tcp LISTEN 0 128 0.0.0.0:22 0.0.0.0:*
users:((("sshd",pid=765,fd=6))
cubic cwnd:10
tcp LISTEN 0 4096 127.0.0.1:39049 0.0.0.0:*
users:((("containerd",pid=755,fd=9))
cubic cwnd:10
tcp LISTEN 0 128 :::22 :::*
users:((("sshd",pid=765,fd=7))
cubic cwnd:10
```

Figure 22: Screenshot of listening ports

```
(kali@kali)~$ systemctl status apache2
○ apache2.service - The Apache HTTP Server
   Loaded: loaded (/usr/lib/systemd/system/apache2.service; disabled; preset:➤
   Active: inactive (dead)
   Docs: https://httpd.apache.org/docs/2.4/
lines 1-4/4 (END)
```

Figure 23: Screenshot of apache2 disabled

Note about this section: I ran the check on all of the services listed in the Kali quick reference table and of all the services that were installed, only apache2 was active.

2.5 SSH Hardening

```
(kali@kali)~$ sudo grep -E "PermitRootLogin|PermitEmptyPasswords|MaxAuthTries|X11Forwardin
g" /etc/ssh/sshd_config
PermitRootLogin no
#MaxAuthTries 6
#PermitEmptyPasswords no
# the setting of "PermitRootLogin prohibit-password".
X11Forwarding yes
# X11Forwarding no
```

Figure 24: Screenshot of current SSH daemon configuration

```
(kali@kali)~$ sudo sshd -T | grep -E "permitrootlogin|permitemptypasswords|maxauthtries|x1
lforwarding"
maxauthtries 3
permitrootlogin no
x11forwarding no
permitemptypasswords no
```

Figure 25: Screenshot of hardened SSH configuration

3 CIS Benchmark Comparison

3.1 Linux CIS Benchmark Checks

1. 5.6.1.1 Ensure password expiration is 365 days or less

- **Check Command:** `grep PASS_MAX_DAYS /etc/login.defs`



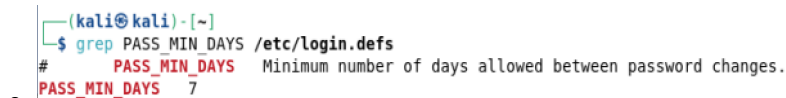
```
(kali㉿kali)-[~]  
$ grep PASS_MAX_DAYS /etc/login.defs  
# PASS_MAX_DAYS Maximum number of days a password may be used.  
PASS_MAX_DAYS 90
```

Figure 26.1: Screenshot of check command output

- **Result (Pass/Fail):** PASS_MAX_DAYS 90 ; *PASS*

2. 5.6.1.2 Ensure minimum days between password changes is 1 or more

- **Check Command:** `grep PASS_MIN_DAYS /etc/login.defs`



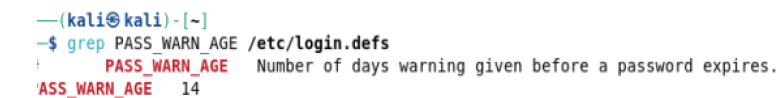
```
(kali㉿kali)-[~]  
$ grep PASS_MIN_DAYS /etc/login.defs  
# PASS_MIN_DAYS Minimum number of days allowed between password changes.  
PASS_MIN_DAYS 7
```

Figure 26.2: Screenshot of check command output

- **Result (Pass/Fail):** PASS_MIN_DAYS 7 ; *PASS*

3. 5.6.1.3 Ensure password expiration warning is 7 or more days

- **Check Command:** `grep PASS_WARN_AGE /etc/login.defs`



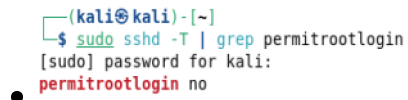
```
(kali㉿kali)-[~]  
$ grep PASS_WARN_AGE /etc/login.defs  
# PASS_WARN_AGE Number of days warning given before a password expires.  
PASS_WARN_AGE 14
```

Figure 26.3: Screenshot of check command output

- **Result (Pass/Fail):** PASS_WARN_AGE 14 ; *PASS*

4. 5.2.7 Ensure SSH root login is disabled

- **Check Command:** `sudo sshd -T | grep permitrootlogin`



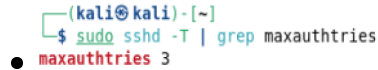
```
(kali㉿kali)-[~]
└─$ sudo sshd -T | grep permitrootlogin
[sudo] password for kali:
permitrootlogin no
```

Figure 26.4: Screenshot of check command output

- **Result (Pass/Fail):** `permitrootlogin no` ; *PASS*

5. 5.2.11 Ensure SSH MaxAuthTries is set to 4 or fewer

- **Check Command:** `sudo sshd -T | grep maxauthtries`



```
(kali㉿kali)-[~]
└─$ sudo sshd -T | grep maxauthtries
maxauthtries 3
```

Figure 26.5: Screenshot of check command output

- **Result (Pass/Fail):** `maxauthtries 3` ; *PASS*

3.2 Windows CIS Benchmark Checks

1. 1.1.1 Ensure 'Enforce password history' is set to 5 or more passwords

- **Check Command:**
- *Figure 26.6: Screenshot of...*
- **Result (Pass/Fail):**

2. 1.1.4 Ensure 'Minimum password length' is set to 14 or more characters

- **Check Command:**
- *Figure 26.7: Screenshot of...*
- **Result (Pass/Fail):**

3. 1.2.1 Ensure 'Account lockout duration' is set to 15 or more minutes

- **Check Command:**
- *Figure 26.8: Screenshot of...*
- **Result (Pass/Fail):**

4 Security Policy Draft

5 Reflection Questions

5.1 Policy vs. Technical Controls

5.2 Defense in Depth

++report written with (minimal) help from Claude (Sonnet 4.6)++